

Report Pratica

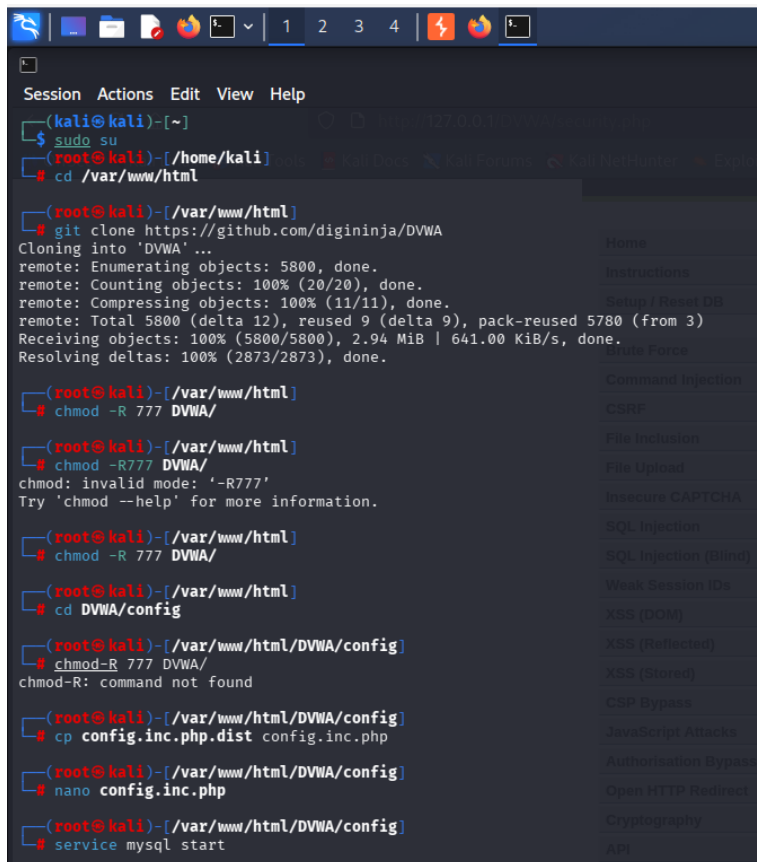
Installazione e configurazione di DVWA con intercettazione del traffico via Burp Suite

Obiettivo della pratica

L'obiettivo di questa pratica è installare e configurare DVWA (Damn Vulnerable Web Application) su Kali Linux, un'applicazione web volutamente vulnerabile usata per esercitarsi sulle tecniche di penetration testing, e successivamente analizzare le richieste HTTP generate dall'applicazione tramite Burp Suite.

Clonazione di DVWA e configurazione iniziale

Ho iniziato ottenendo i privilegi di root, spostandomi nella cartella /var/www/html e clonando il repository ufficiale di DVWA da GitHub. Ho poi impostato i permessi sulla cartella DVWA/, copiato il file di configurazione di esempio (config.inc.php.dist) in config.inc.php, aperto quest'ultimo con l'editor nano per modificarlo, e infine avviato il servizio MySQL:



```
(kali@kali)-[~]
└─$ sudo su
(root@kali)-[/home/kali]
└─# cd /var/www/html

(root@kali)-[/var/www/html]
└─# git clone https://github.com/digininja/DVWA
Cloning into 'DVWA' ...
remote: Enumerating objects: 5800, done.
remote: Counting objects: 100% (20/20), done.
remote: Compressing objects: 100% (11/11), done.
remote: Total 5800 (delta 12), reused 9 (delta 9), pack-reused 5780 (from 3)
Receiving objects: 100% (5800/5800), 2.94 MiB | 641.00 KiB/s, done.
Resolving deltas: 100% (2873/2873), done.

(root@kali)-[/var/www/html]
└─# chmod -R 777 DVWA/

(root@kali)-[/var/www/html]
└─# chmod -R777 DVWA/
chmod: invalid mode: '--R777'
Try 'chmod --help' for more information.

(root@kali)-[/var/www/html]
└─# chmod -R 777 DVWA/

(root@kali)-[/var/www/html]
└─# cd DVWA/config

(root@kali)-[/var/www/html/DVWA/config]
└─# chmod-R 777 DVWA/
chmod-R: command not found

(root@kali)-[/var/www/html/DVWA/config]
└─# cp config.inc.php.dist config.inc.php

(root@kali)-[/var/www/html/DVWA/config]
└─# nano config.inc.php

(root@kali)-[/var/www/html/DVWA/config]
└─# service mysql start
```

Creazione dell'utente e dei permessi del database

Ho avviato il client MySQL come root e creato un nuovo utente dedicato al database di DVWA, kali, associato all'host 127.0.0.1:

```
(root@kali)-[/var/www/html/DVWA/config]
# mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 5
Server version: 11.8.8-MariaDB-1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create user 'kali'@'127.0.0.1' identified by 'kali' ;
Query OK, 0 rows affected (0.010 sec)
```

Successivamente ho assegnato a questo utente tutti i privilegi sul database dvwa e sono uscito dalla shell di MySQL. Ho poi navigato nella cartella di configurazione di PHP per individuare il file php.ini da modificare:

```
1
MariaDB [(none)]> grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali' ;
Query OK, 0 rows affected (0.011 sec)

MariaDB [(none)]> exit
Bye

(root@kali)-[/var/www/html/DVWA/config]
# cd /etc/php

(root@kali)-[/etc/php]
# ls
8.4

(root@kali)-[/etc/php]
# cd /etc/8.4/apache2
cd: no such file or directory: /etc/8.4/apache2

(root@kali)-[/etc/php]
# cd /etc/php/8.4/apache2

(root@kali)-[/etc/php/8.4/apache2]
# ls
```

Configurazione del file config.inc.php

Ho aperto il file config.inc.php per impostare i parametri di connessione al database (host, nome database, utente e password) in linea con l'utente MySQL appena creato, oltre alle impostazioni relative a reCAPTCHA e al livello di sicurezza predefinito:

```
# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to DVWA.
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$DVWA = array();
$DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$DVWA['db_user'] = getenv('DB_USER') ?: 'kali';
$DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'kali';
$DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
# Default value for the security level with each session.
# The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or 'impossible'.
$DVWA['default_security_level'] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'impossible';

# Default locale
# Default locale for the help page shown with each session.
# The default is 'en'. You may wish to set this to either 'en' or 'zh'.
$DVWA['default_locale'] = getenv('DEFAULT_LOCALE') ?: 'en';

# Disable authentication
# Some tools don't like working with authentication and passing cookies around
# so this setting lets you turn off authentication.
$DVWA['disable_authentication'] = getenv('DISABLE_AUTHENTICATION') ?: false;

define('MYSQL', 'mysql');
define('SQLITE', 'sqlite');

# SQLite DB Backend
```

In particolare ho verificato che i parametri db_user e db_password fossero impostati correttamente sul valore kali, coerente con l'utente creato in precedenza su MariaDB:

```
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$DVWA = array();
$DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$DVWA['db_user'] = getenv('DB_USER') ?: 'kali';
$DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'kali';
$DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
```

Modifica del file php.ini

Per consentire il corretto funzionamento dei laboratori di file inclusion, ho modificato il file php.ini abilitando le direttive allow_url_fopen e allow_url_include, entrambe impostate su On:

```
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as files.
; https://php.net/allow-url-include
allow_url_include = On
```

Verifica dell'installazione (Setup Check)

Dalla pagina "Setup / Reset DB" di DVWA ho controllato l'esito del Setup Check, che riepiloga lo stato generale del sistema: sistema operativo, versione di DVWA, chiave reCAPTCHA, permessi delle cartelle, versione di Apache e PHP, e parametri di connessione al database:

If the database already exists, **it will be cleared and the data will be reset.**
You can also use this to reset the administrator credentials ("admin // password") at any stage.

Setup Check

General

Operating system: ***nix**

DVWA version:

- Git reference: **5d5c76cced604e54462b13723f5c69af58e78748**
- Author: Robin Wood

reCAPTCHA key: **Missing**

Writable folder /var/www/html/DVWA/hackable/uploads/: **Yes**

Writable folder /var/www/html/DVWA/config: **Yes**

Apache

Web Server SERVER_NAME: **127.0.0.1**

mod_rewrite: **Not Enabled**

mod_rewrite is required for the API labs.

PHP

PHP version: **8.4.24**

PHP function display_errors: **Disabled**

PHP function display_startup_errors: **Disabled**

PHP function allow_url_include: **Enabled** - Feature deprecated in PHP 7.4, see lab for more information

PHP function allow_url_fopen: **Enabled**

PHP module gd: **Missing - Only an issue if you want to play with captchas**

PHP module mysql: **Installed**

PHP module pdo_mysql: **Installed**

Database

Backend database: **MySQL/MariaDB**

Database username: **kali**

Database password: *********

Database database: **dvwa**

Database host: **127.0.0.1**

Database port: **3306**

API

This section is only important if you want to use the API module.

Vendor files installed: **Not Installed**

For information on how to install these, see the [README](#).

Status in red, indicate there will be an issue when trying to complete some modules.

Ho poi verificato nel dettaglio lo stato dei moduli PHP e del database, notando che le funzioni allow_url_fopen e allow_url_include risultavano correttamente abilitate, mentre il modulo mod_rewrite non era attivo (non necessario per gli scopi di questa esercitazione):

Apache

Web Server SERVER_NAME: 127.0.0.1

mod_rewrite: **Not Enabled**

mod_rewrite is required for the API labs.

PHP

PHP version: 8.4.24

PHP function display_errors: **Disabled**

PHP function display_startup_errors: **Disabled**

PHP function allow_url_include: **Enabled** - Feature deprecated in PHP 7.4, see lab for more information

PHP function allow_url_fopen: **Enabled**

PHP module gd: **Missing - Only an issue if you want to play with captchas**

PHP module mysql: **Installed**

PHP module pdo_mysql: **Installed**

Database

Backend database: MySQL/MariaDB

Database username: kali

Database password: *****

Database database: dvwa

Database host: 127.0.0.1

Database port: 3306

API

This section is only important if you want to use the API module.

Vendor files installed: **Not Installed**

For information on how to install these, see the [README](#).

Status in red, indicate there will be an issue when trying to complete some modules.

If you see disabled on either `allow_url_fopen` or `allow_url_include`, set the following in your php.ini file and restart Apache.

`allow_url_fopen = On`

`allow_url_include = On`

These are only required for the file inclusion labs so unless you want to play with those, you can ignore them.

Create / Reset Database

Reset del database e impostazione del livello di sicurezza

Dopo aver eseguito il reset/creazione del database, ho effettuato l'accesso a DVWA e impostato il livello di sicurezza dell'applicazione su low, il livello più vulnerabile, pensato per esercitarsi sulle tecniche di exploitation di base:

The screenshot shows the DVWA Security page. On the left is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript Attacks, Authorisation Bypass, Open HTTP Redirect, Cryptography, API, DVWA Security (highlighted), PHP Info, About, and Logout. The main content area is titled 'DVWA Security' with a padlock icon. Below this is the 'Security Level' section, which states 'Security level is currently: low.' and explains that the security level can be set to low, medium, high, or impossible. It lists four levels: 1. Low (completely vulnerable, no security measures), 2. Medium (example of bad security practices), 3. High (extension of medium difficulty with harder or alternative bad practices), and 4. Impossible (secure against all vulnerabilities). A dropdown menu is set to 'Low' and a 'Submit' button is visible. Below this is the 'Additional Tools' section with a link to 'View Broken Access Control Logs'. At the bottom, a box indicates 'Security level set to low'.

DVWA Security

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

Low

Additional Tools

- [View Broken Access Control Logs](#) - View access logs for the Broken Access Control vulnerability

Security level set to low

Intercettazione del traffico con Burp Suite

Infine ho configurato il browser per instradare il traffico attraverso il proxy di Burp Suite e ho attivato l'intercettazione delle richieste. Nella prima cattura si vede una richiesta GET alla pagina principale di DVWA, effettuata prima dell'autenticazione (senza cookie di sessione):

The screenshot displays the Burp Suite Community Edition v2026.8 interface. The top menu bar includes options like Burp, Project, Intruder, Repeater, View, and Help. Below the menu is a toolbar with buttons for Dashboard, Target, Proxy (selected), Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. The 'Proxy' tab is active, showing a table of intercepted requests. The first request is selected, and its details are shown in the 'Request' pane on the left and the 'Inspector' pane on the right.

Request

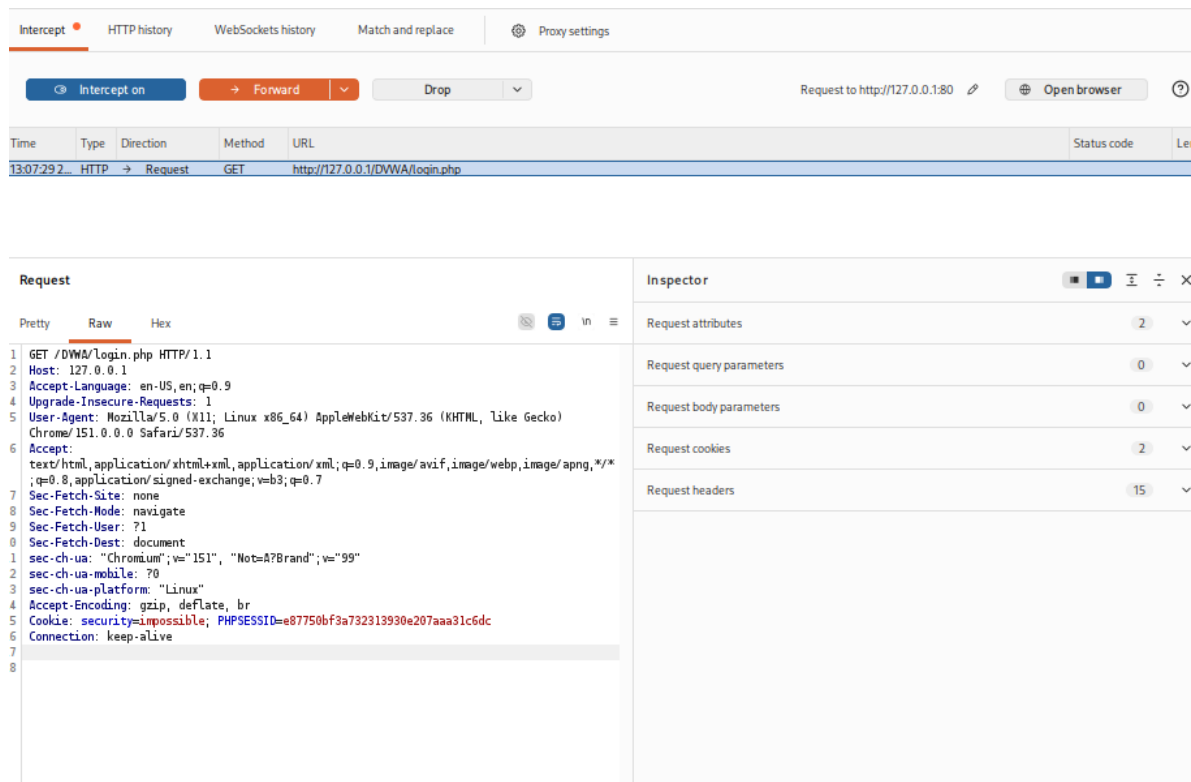
Pretty Raw Hex

```
1 GET /DVWA/ HTTP/1.1
2 Host: 127.0.0.1
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Sec-Fetch-Site: none
8 Sec-Fetch-Mode: navigate
9 Sec-Fetch-User: ?1
10 Sec-Fetch-Dest: document
11 sec-ch-ua: "Chromium",v="151", "Not=A?Brand";v="99"
12 sec-ch-ua-mobile: ?0
13 sec-ch-ua-platform: "Linux"
14 Accept-Encoding: gzip, deflate, br
15 Connection: keep-alive
16
17
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 0
- Request cookies: 0
- Request headers: 14

In una seconda richiesta, verso la pagina di login (login.php), sono invece visibili i cookie di sessione già impostati dal browser, tra cui security (che riflette il livello di sicurezza configurato) e PHPSESSID, l'identificativo di sessione PHP:



Conclusioni

Attraverso questa pratica ho imparato a:

- Installare DVWA da sorgente su una macchina Kali Linux, replicando il repository e configurando i permessi necessari
- Creare un utente MySQL dedicato e assegnargli i privilegi sul database dell'applicazione
- Configurare correttamente i file config.inc.php e php.ini per il corretto funzionamento dell'applicazione
- Utilizzare la pagina di Setup Check per diagnosticare eventuali problemi di configurazione dell'ambiente
- Impostare il livello di sicurezza di DVWA in base al tipo di esercitazione da svolgere
- Utilizzare Burp Suite per intercettare e analizzare le richieste HTTP scambiate tra browser e applicazione, inclusi i cookie di sessione

Questa esercitazione ha fornito le basi pratiche per l'ambiente di lavoro necessario ad affrontare, nelle prossime attività, le singole vulnerabilità presenti in DVWA (SQL Injection, XSS, CSRF, ecc.).